

Vulnerability Assessment Report

1st January 20XX

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

This vulnerability assessment aims to show that the database server is vulnerable to attack and should be secured with better access controls. The data on the server is essential for the business, as it includes customer, campaign, and analytic data used for marketing efforts. Any security incident affecting the server itself would completely suspend normal business operations. Thus, it is critical for the server to be secured from attack and the data to be protected from loss, modification, or theft.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Hacker	Obtain sensitive information via exfiltration	3	3	9
Employee	Disrupt mission-critical operations	2	3	6
Customer	Alter/Delete critical information	1	3	3

Approach

Measurements of risks considered that the business stores and manages its data in an open-access system, exposing the data to tampering and attack by human actors. Analysis of potential threats took into account the motives that both outsiders and insiders have to take advantage of the server's lack of security. The impacts of the potential threat events were decided in light of daily operational reliance on the database.

Remediation Strategy

The business should implement authentication, authorization, and auditing (AAA) mechanisms to ensure that only authorized users access the database server. This includes using strong passwords, role-based access controls (RBAC), and multi-factor authentication (MFA), in order to maintain the principle of least privilege. The business should also implement IP allow-listing to corporate offices, so that random Internet users are prevented from connecting to the database.